

INSIDER THREAT REMEDIATION REPORT

BY
AISHA DUZE
MAY 2026

EXECUTIVE SUMMARY

The Core Problem

The IRS has loopholes with their offboarding process, especially where IT is concerned. An ex-employee retained live credentials, API access, and likely admin panel access after leaving the organization. This is a classic *insider threat* scenario, resulting from technical and governance failures. The GRC Response was structured across three pillars:

Governance — The implementation a formal offboarding standard operating procedure(SOP) that mandates credential revocation within hours of any departure (voluntary or otherwise). A system owner must be assigned to every application, and legal counsel should assess whether criminal charges apply under computer misuse legislation.

Risk Management — Every database change since the employee's departure was forensically audited to determine what was altered. The risk register was updated and notification obligations were triggered under data protection law based on the altered or corrupted taxpayer data.

Compliance — The key frameworks that apply are ISO 27001 (particularly A.9 Access Control and A.16 Incident Management) and NIST SP 800-53 (AC-2 Account Management, IR-4 Incident Handling). A third-party audit post-incident was strongly advised.

The 4-Phase Action Plan moved from emergency containment (revoke everything now) → forensic investigation → system hardening → long-term governance maturity including quarterly access reviews and eventual ISO 27001 certification.

INCIDENT SUMMARY

Threat type: Insider

Risk Level: Critical

GRC Response: 4-phase

ACCESS FAILURE & REMEDIATION:

Current State:

An ex-employee was not properly offboarded and retained credentials granting access to

- Direct APIs to the app server, accessing the self-assessment portal. This reveals a lack of access controls.
- Admin portal, enabling configuration and user management due to shared or super admin access to credentials.
- the taxpayer database, accessing taxpayer records as there is no audit logging in place.

Impact:

- a) Service disruptions
- b) Data integrity at risk

Remediated state:

1. IAM + Zero Trust:

- a) enforce strict SOP with an offboarding checklist
- b) MFA on all user accounts
- c) Least privilege RBAC

2. WAF + API Gateway:

- a) IP allowlisting
- b) Rate limiting
- c) Token authorized

This will also include:

2b. SIEM + Audit Log aligned ISO 27001/NIST:

- a) All access logged
- b) Anomaly detection
- c) Real-time alerts
- d) Immutable audit trail
- e) Forensic retention
- f) Enabled legal hold

3. Hardened App Server

- a) Patched and re-keyed to isolate from the ex-staff

4. Secured Taxpayer DB

- a) Encryption at rest
- b) Db firewall with row-level security

Outcome:

- Service restored and protected

- Data integrity is ensured.
- Active continuous monitoring

GRC RESPONSE:

Governance:

- Establish a formal offboarding policy with mandatory access revocation within an hour of termination
- Define a Privileged Access Management (PAM) policy requiring approval workflows for all admin credentials
- Assign data owners and system owners for each application component.
- Conduct an emergency Board/leadership-level incident review
- Update the Acceptable Use and Access Control policies to cover contractor/developer roles
- Engage legal counsel to assess criminal liability and pursue prosecution where applicable

Risk:

- Update the risk register and classify the incident as a critical insider threat
- Perform full threat modeling of all systems that the ex-employee has access to
- Assess data integrity; audit all DB changes made after the employee left.
- Evaluate the regulatory exposure(data protections laws, taxpayer confidentiality, etc)
- Engage a cyber insurance provider and notify the relevant regulatory authorities where required
- Implement ongoing insider threat monitoring as a permanent risk control

Compliance:

- Map controls to ISO 27001 A.9 (Access Control) and A.16 (Incident Management)
- Align with NIST SP 800-53 AC-2 (Account Management) and IR-4 (Incident Handling)
- Ensure data protection obligations are met under applicable privacy legislation
- Produce a mandatory incident report for the relevant oversight body or regulator
- Conduct a post-incident compliance audit with an independent third party
- Schedule quarterly access reviews as a standing requirement for compliance

THE 4-PHASED ACTION PLAN

01

IMMEDIATE (0–24 HRS)- Emergency Containment

- Revoke ALL ex-employee credentials immediately
- Rotate API keys, service account passwords & tokens
- Block IP addresses associated with ex-employee
- Force-expire all active sessions
- Preserve all system logs for forensic investigation
- Notify the incident response team & senior management
- Enable emergency change freeze on the application(s)

02

SHORT TERM (1–7 DAYS)- Investigation and damage assessment

- Forensic audit of all DB changes since departure date
- Review git history & deployment logs for backdoors
- Conduct full vulnerability scan of the application
- Implement MFA on all remaining accounts
- Deploy Web Application Firewall (WAF)
- Engage legal for potential criminal referral
- Notify affected taxpayers if data was compromised

03

MEDIUM TERM (1–4 WEEKS) – Hardening & Policy Reforms

- Implement Role-Based Access Control (RBAC)
- Deploy SIEM with insider threat detection rules
- Separate environments: dev / staging / production
- Enforce least-privilege principle across all systems
- Formalise offboarding SOP with mandatory checklist
- Introduce PAM solution for privileged accounts
- Conduct security awareness training for all staff

LONG TERM (1–3 MONTHS)- Continuous Monitoring & Governance Maturity

Quarterly access reviews by system owners

Annual third-party penetration testing

Automated user access certification process

Immutable audit logging with legal hold capability

Embed GRC into SDLC for all future development

Achieve ISO 27001 certification as a target

Use a Board-level cyber risk reporting cadence

KEY CONTROLS & RISK REGISTER

CONTROL	FRAMEWORK REF	RISK ADDRESSED		PRIORITY	OWNER
Immediate credential revocation	ISO 27001 A.9.2.6/NIST AC-2	Ongoing access	unauthorized	CRITICAL	IT Security/HR
MFA enforcement	NIST IA-2/ISO A.9.4	Credential compromise		HIGH	IT Security
SIEM & audit logging	ISO A.12.4 /NIST AU-2	Undetected future attacks		HIGH	SOC/IT Ops
Least-privilege RBAC	ISO A.9.1/NIST AC-6	Excessive access rights		HIGH	IT Security
Offboarding SOP	ISO A.7.3. /NIST PS-4	Recurrence of this scenario		HIGH	HR/CISO
WAF & API Gateway	NIST SC-7/ISO A.13	External attack surface		MEDIUM	Network/IT
Privileged Access Management	ISO A.9.4.4/NIST AC-17	Uncontrolled accounts	admin	MEDIUM	IT Security
Penetration Testing(quarterly)	ISO A.14.2.8/NIST CA-8	Unknown vulnerabilities		MEDIUM	CISO/Third Party
Quarterly access reviews	ISO A.9.2.5/NIST AC-2(7)	Access creep over time		ONGOING	System Owners
Legal referral/prosecution	Computer Misuse Act/NDPA/other local law	Deterrence accountability		& HIGH	Legal/Management